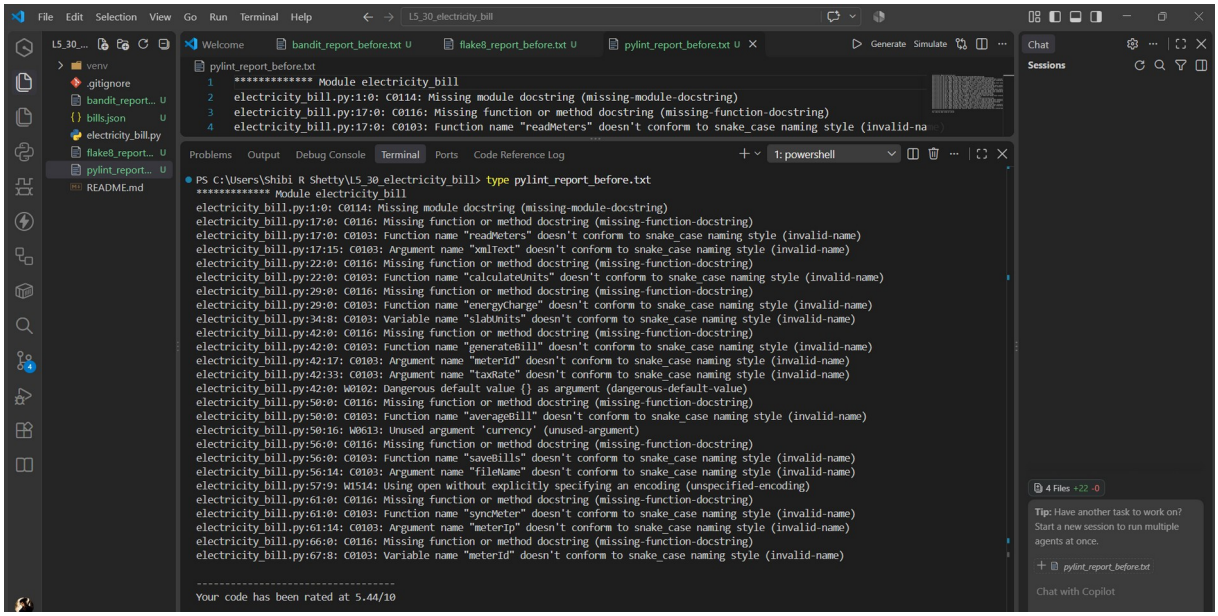
Lab 5: Static Code Analysis

NAME: SHIBI R SHETTY SRN: PES2UG24CS467

GITLINK: https://github.com/shibishetty77/L5_30_electricity_bill

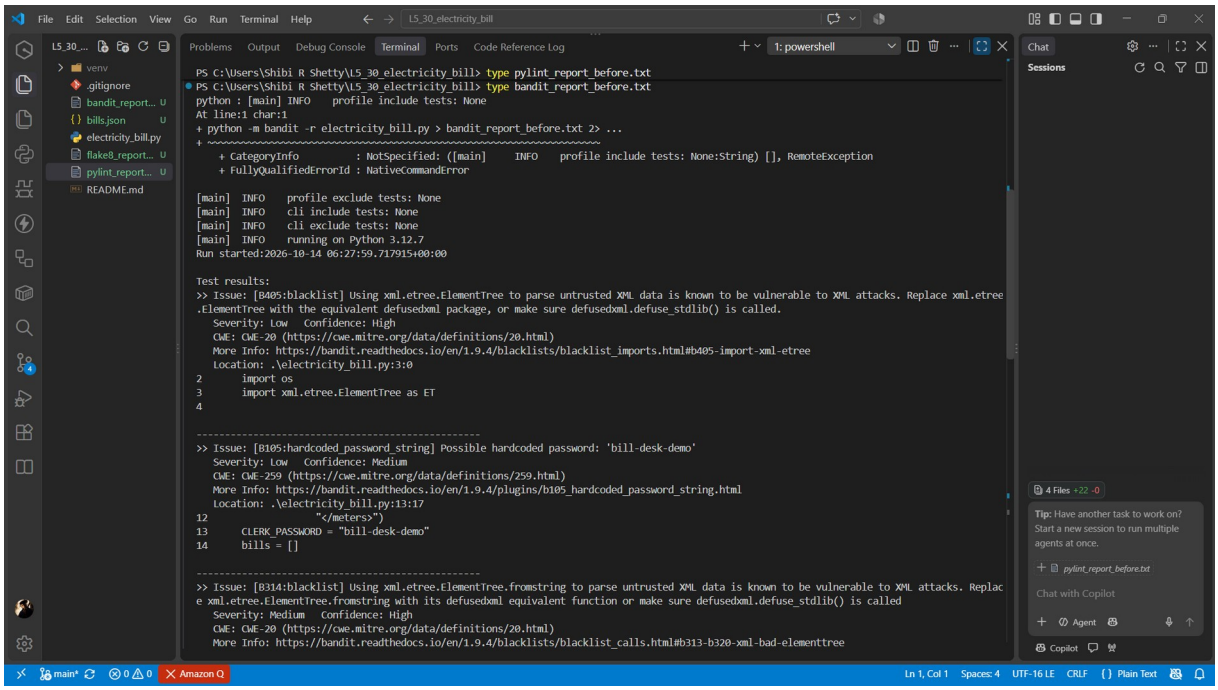
BEFORE: Pylint output



The first Pylint run scored 5.44/10. It reported missing docstrings, naming issues, a mutable default argument, an unused argument, and file-handling warnings.

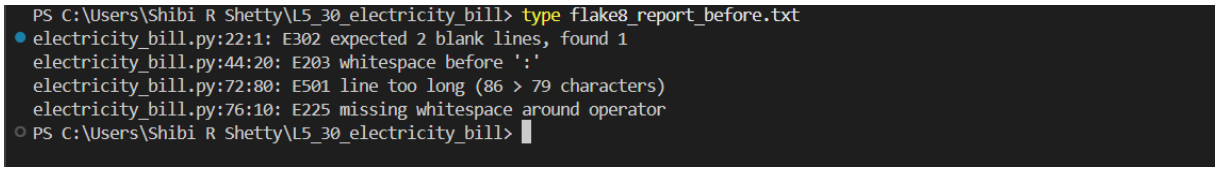
Lab 5: Static Code Analysis — BEFORE

Bandit output



The first Bandit run showed four findings: two low, one medium, and one high. These included XML parsing concerns and a hardcoded password-like value.

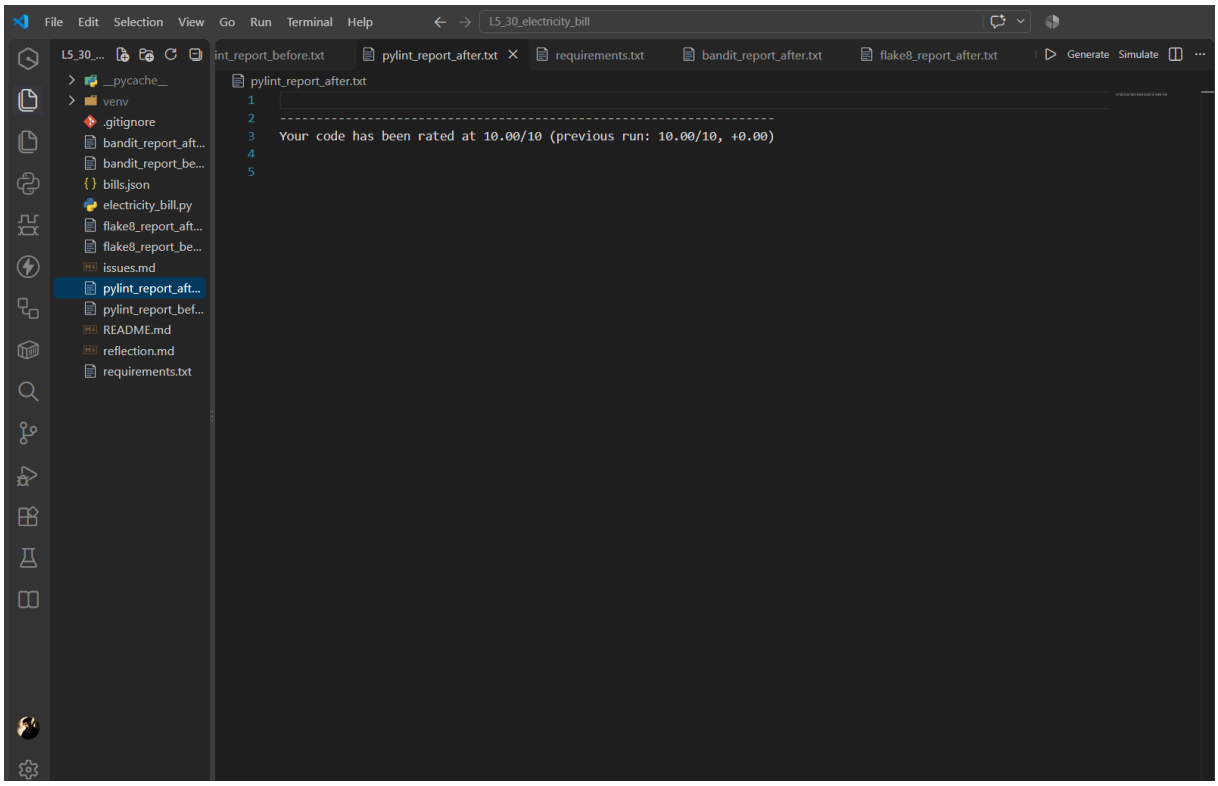
Before Flake8 output



Flake8 reported E302, E203, E501 (an 86-character line), and E225.

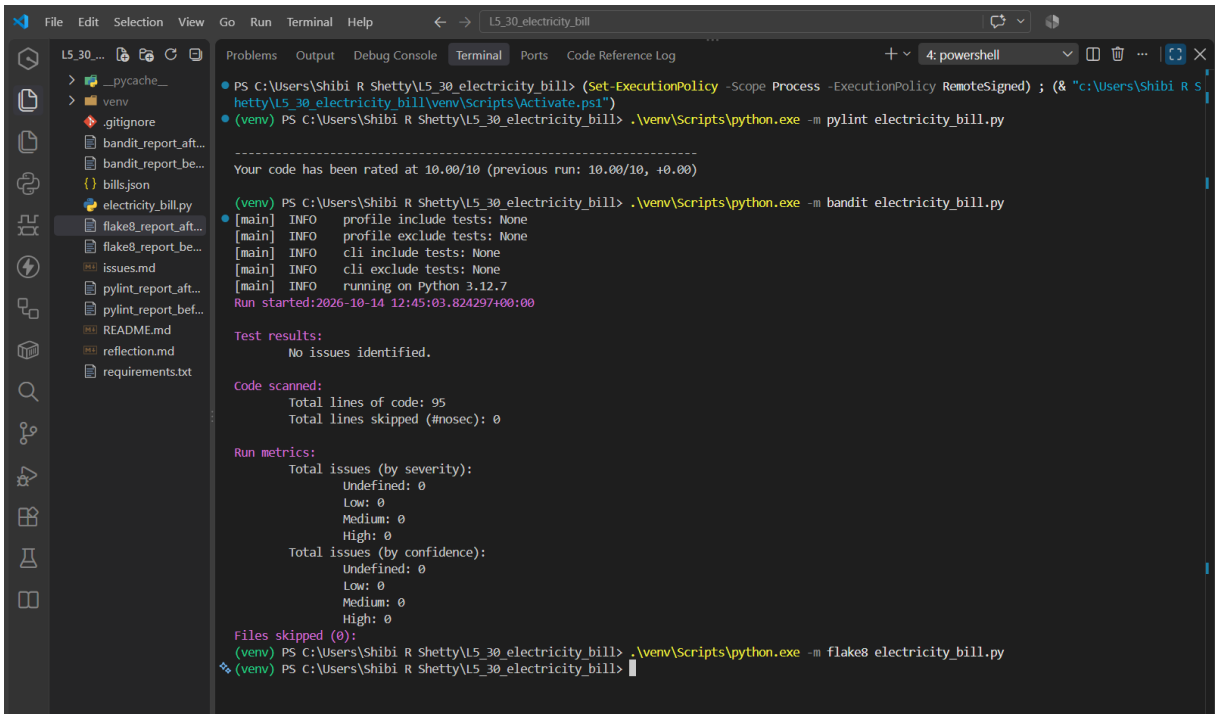
Lab 5: Static Code Analysis — AFTER

Pylint output



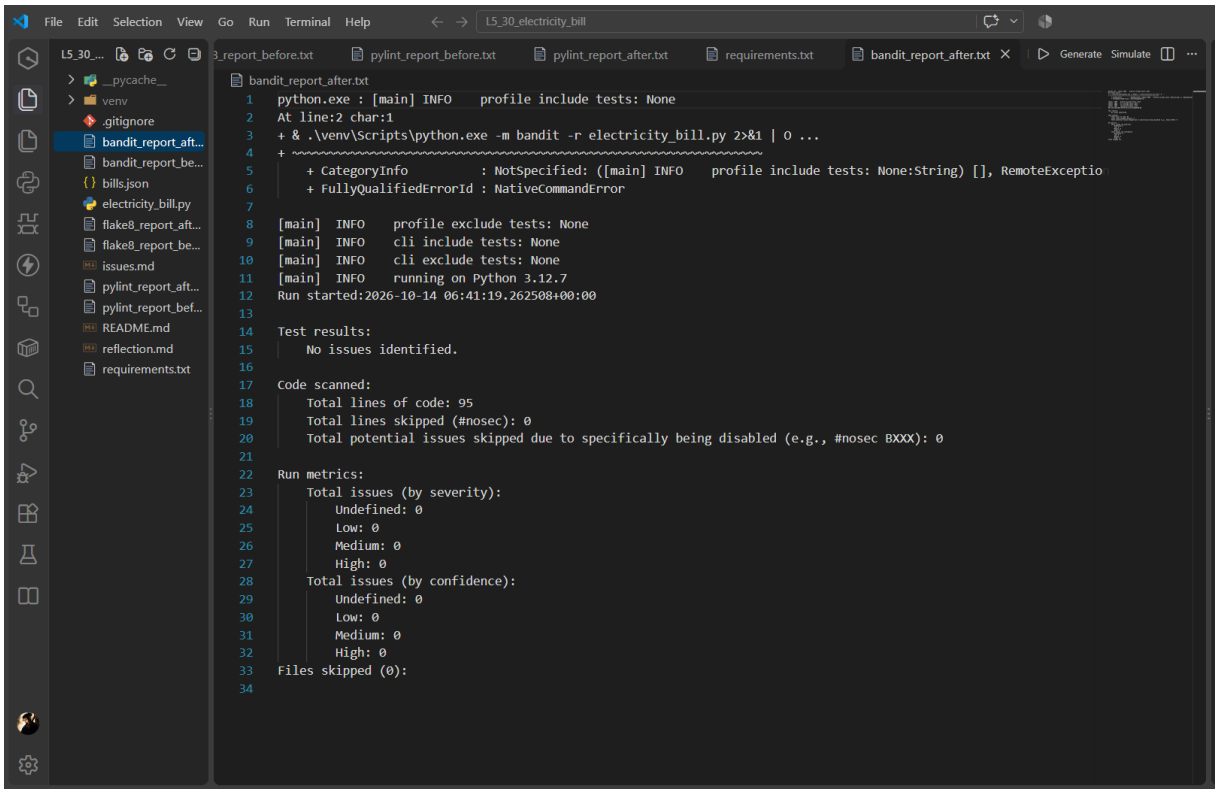
After the changes, Pylint gave the program a score of 10.00/10.

Final terminal verification



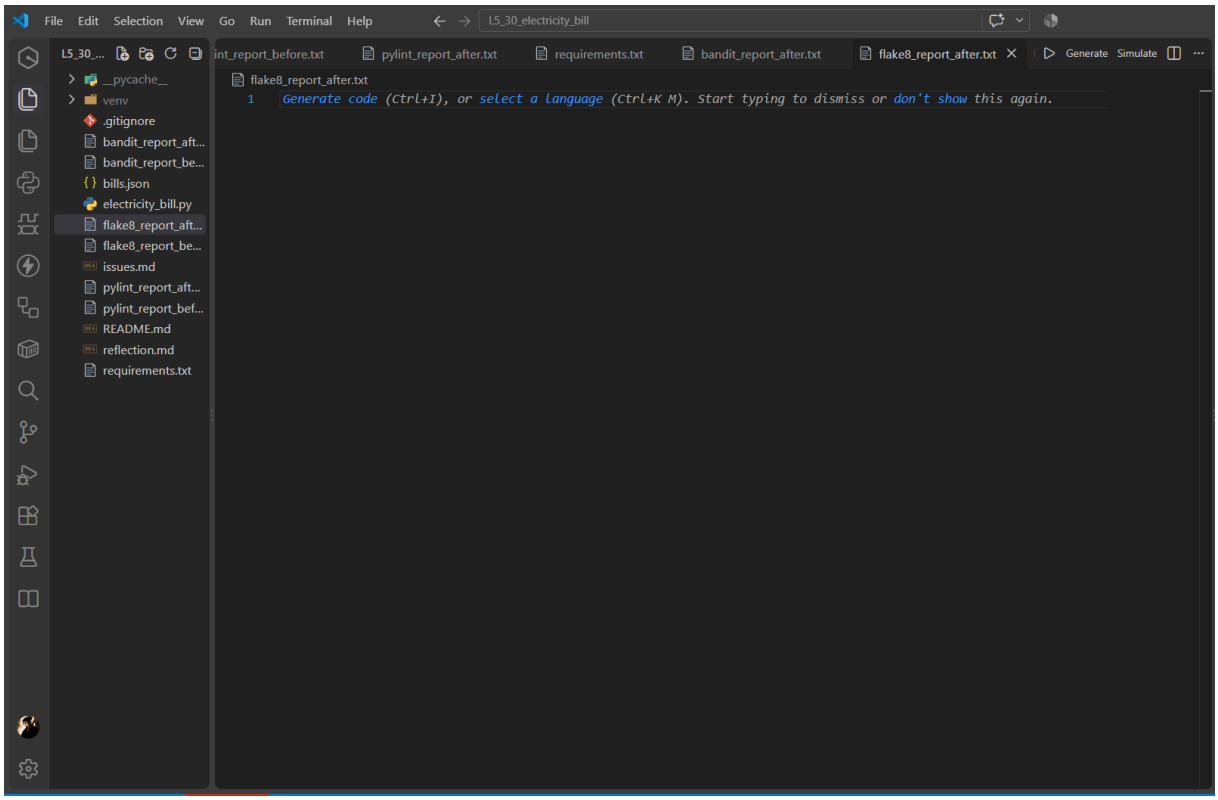
Lab 5: Static Code Analysis — AFTER

Bandit output



Bandit reported no issues. The summary showed zero findings at every severity level.

Flake8 output



The Flake8 report is empty, and the terminal run showed no violations.

Issue Documentation Table

Issue Type	Line(s)	Description	Fix Approach
Shell command injection risk (Bandit B605 — High)	63	The original code constructed a curl shell command from a meter address, which could allow shell metacharacters to alter the command.	Replaced shell invocation with HTTPConnection; validated the IP using ipaddress.ip_address, applied a timeout, checked HTTP status, and closed the connection.
Unsafe XML parsing (Bandit B314/B405)	3, 18	Standard ElementTree parsing of XML can be unsafe when input is untrusted.	Used defusedxml.ElementTree for safer XML parsing.
Hardcoded password-like string (Bandit B105)	13	An unused hardcoded password-like value existed in the source.	Removed the unused credential because the demonstration does not require clerk authentication.
Mutable default argument (Pylint W0102)	42	A dictionary default could be shared across calls.	Use None as the default and initialize a fresh dictionary inside the function.
Unused argument (Pylint W0613)	50	The currency argument was not used by averageBill.	Removed the unused parameter and updated the call to average_bill().
Missing file encoding (Pylint W1514)	57	The file-opening operation did not specify an encoding.	Used encoding='utf-8' when opening the JSON output file.
Naming and documentation (Pylint C0103/C0114/C0116)	1, 17, 22, 29, 34, 42, 50, 56, 61, 67	Module/functions lacked documentation or used camelCase identifiers.	Added docstrings and changed identifiers to snake_case.
Whitespace and line length (Flake8 E302/E203/E501/E225)	22, 44, 72, 76	The code had spacing, whitespace, line-length, and operator-spacing violations.	Corrected blank lines, removed whitespace before the colon, wrapped the long line, and spaced the operator.

Results after the fixes: Pylint 10.00/10, no Bandit findings, and no Flake8 violations shown.

Git repository: https://github.com/shibishetty77/L5_30_electricity_bill